Replace and modernize legacy VPN architectures with a cloud-native Zscaler Zero Trust solution to reduce attack surface and lateral movement

Stage-1

Overview:

Modern organizations rely heavily on remote connectivity for employees, vendors, and external partners. Traditionally, organizations used Virtual Private Network (VPN) solutions to provide remote access to internal systems. However, legacy VPN architectures follow a perimeter-based security model where once users authenticate, they are trusted and allowed broad access to internal network resources. This approach significantly increases the attack surface and allows attackers to move laterally across the network if credentials are compromised.

To overcome these limitations, organizations are moving toward a Zero Trust security model. The Zero Trust approach follows the principle of “Never Trust, Always Verify.” Instead of providing full network access, Zero Trust ensures that users only gain access to specific applications after identity verification, device validation, and security policy checks.

In this project, we explore how a cloud-native Zero Trust architecture using Zscaler can replace traditional VPN systems. Zscaler Private Access (ZPA) connects users directly to applications instead of the internal network. This architecture reduces the attack surface and prevents lateral movement within the network.

Along with architectural improvements, this project also focuses on identifying vulnerabilities present in web applications using practical security testing techniques. Using OWASP Top 10 principles, vulnerabilities such as insecure headers, outdated encryption protocols, improper input validation, and information disclosure were analyzed.

The practical analysis was performed on the practice website **http://www.itsecgames.com**, which is intentionally designed to demonstrate security weaknesses. Multiple vulnerabilities were identified including missing security headers, TLS protocol issues, and API vulnerabilities.

The goal of this project is to demonstrate how identifying vulnerabilities and implementing Zero Trust architecture together can improve overall security posture.

List of teammates

S.no	Name	College	Contact
1	JAIBHARATHI P	Kaamadhenu Arts and Science	lokesh.cs23@kascsathy.ac.in
2	ESWARAN M	Kaamadhenu Arts and Science	vijayaprasath.cs23@kascsathy.ac.in
3	GOKULRAJ S	Kaamadhenu Arts and Science	krishnakumar.cs23@kascsathy.ac.in
4	MYTHILI S	Kaamadhenu Arts and Science	vishnupriya.cs23@kascsathy.ac.in
5	NANDHINI R	Kaamadhenu Arts and Science	yuvapriya.cs23@kascsathy.ac.in

List of Vulnerability Table:

Practice Website:

S.no	Vulnerability Name	CWE
1	Improper Sanitization of File Paths	CWE- 284: Improper Access Control
2	Invalid Certificate	CWE-395:Improper Certificate Validation
3	Missing X-Frame-Options Header	CWE-1021: Design Improper Restriction of Rendered UI Layers or Frames
4	X-Content-Type Options Header Missing	CWE -918: Server-Side Request Forgery (SSRF)
5	TLS Version 1.0 Protocol Detection	CWE-327: Use of a Broken or Risky Cryptographic Algorithm

REPORT

Practice Website http://www.itsecgames.com

1) Vulnerability Name: Improper Sanitization of File Paths

CWE-284: Improper Access Control

OWASP Category :A01:2021 – Broken Access Control **Description**

This vulnerability occurs when the application does not properly restrict access to files or resources. Improper sanitization of file paths may allow unauthorized users to access sensitive files stored on the server.

When file paths are not properly validated or sanitized, attackers may manipulate input parameters to access restricted files, configuration data, or sensitive information stored within the system.

Business Impact

This vulnerability can have serious security consequences. Attackers may gain unauthorized access to confidential data, system configuration files, or sensitive resources. This may lead to:

- Data breaches
- Exposure of confidential information
- Privacy violations
- Loss of user trust
- Potential regulatory or legal issues

Organizations affected by this vulnerability may need to apply security patches and update system configurations to prevent unauthorized file access.

Steps to Reproduce

1. Navigate to the vulnerability testing platform.
2. Identify the server IP address associated with the target application.
3. Use an information-gathering platform such as Shodan to analyze the host.

   Example reference used during testing: https://www.shodan.io/host/31.3.96.40

4. Analyze the exposed services and configurations that may reveal improper access control mechanisms.

Recommendation

To mitigate this vulnerability, the following security measures should be implemented:

1. Apply Security Updates

Install the latest security patches and updates provided by Drupal. Security updates often contain fixes for known vulnerabilities and improve overall system protection.

2. Review Configuration

After applying updates, review the Drupal configuration to ensure that private files are properly protected. Verify file permissions and access settings to prevent unauthorized access.

3. Conduct Regular Security Audits

Perform regular vulnerability assessments and security audits to identify potential weaknesses in the system and address them proactively.

4. Implement Strong Access Controls

Ensure that only authorized users can access sensitive files and resources. Restrict file access permissions based on user roles and privileges.

5. Data Minimization

Store only necessary sensitive information on the system. Reducing stored data minimizes the impact of potential security breaches.

2) Vulnerability Name: Invalid Certificate

CWE-395: Improper Certificate Validation

OWASP Category: A07:2021 – Identification and Authentication Failures

Description

Improper certificate validation occurs when an application fails to properly verify the authenticity of an SSL/TLS certificate during communication. If a certificate is invalid or malicious, attackers may impersonate a trusted server and intercept communication between the client and the server.

This vulnerability may allow attackers to conduct **Man-in-the-Middle (MITM) attacks**, where they intercept and manipulate data exchanged between two parties.

Business Impact

Improper certificate validation can lead to several security risks including:

- Man-in-the-Middle attacks
- Data interception and modification
- Unauthorized access to sensitive information
- Malware distribution through spoofed certificates

These risks can compromise user data and damage the organization's reputation.

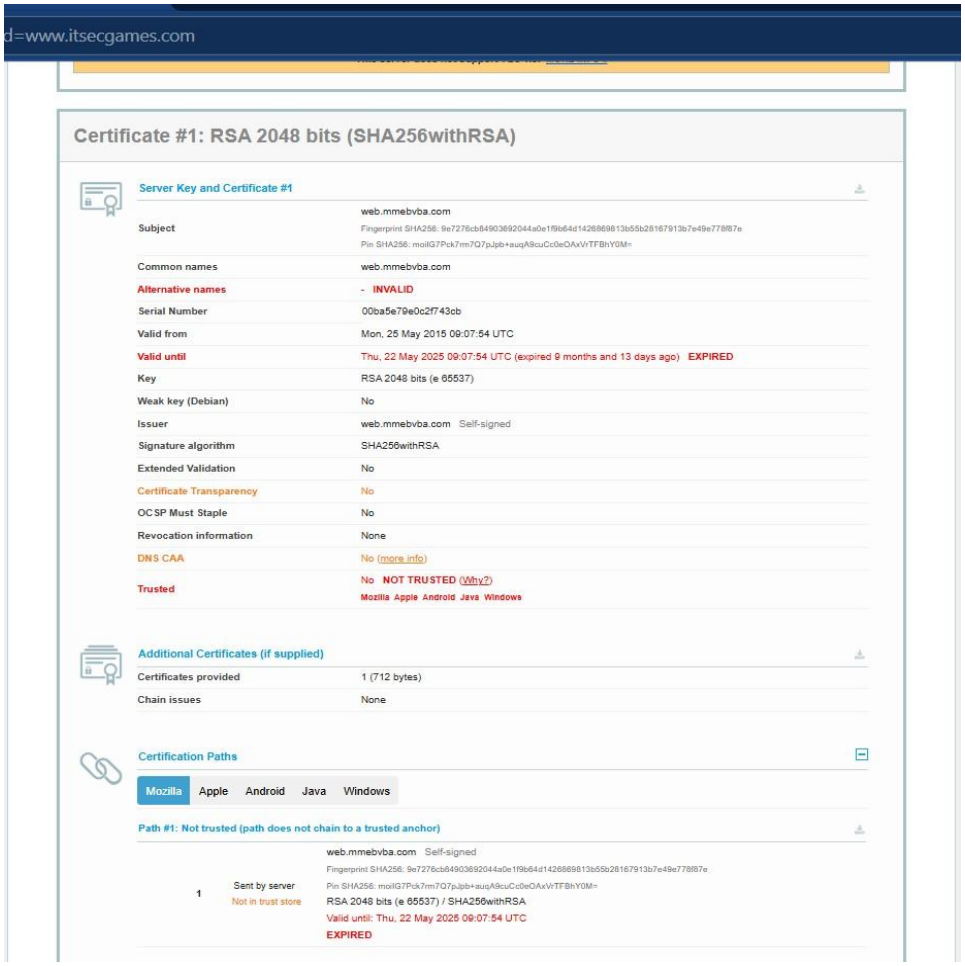
Steps to Reproduce

1. Navigate to the SSL analysis tool.
2. Enter the target domain name of the website.

Example used during testing:

https://www.ssllabs.com/ssltest/analyze?d=www.itsecgames.com

3. Run the SSL analysis and review the certificate validation results.



Recommendation

1. **Use trusted certificate authorities:** Only trust digital certificates issued by wellknown and trusted certificate authorities.

2. **Verify certificate chains:** Verify that the certificate presented by the remote party is valid and issued by a trusted certificate authority. Verify the entire certificate chain, including intermediate certificates.

3. **Check certificate revocation status**: Check the revocation status of the certificate presented by the remote party to ensure that it has not been revoked.

4. **Use certificate pinning:** Implement certificate pinning to ensure that the communication only occurs with the exact certificate or certificate authority specified.

5. **Keep software up to date:** Keep software and security protocols up to date, as new vulnerabilities and security patches are regularly released.

3) Vulnerability Name: Missing X-Frame-Options Header

CWE-1021: Improper Restriction of Rendered UI Layers or Frames

OWASP Category : A04:2021 – Insecure Design

Description

The **X-Frame-Options** header prevents web pages from being embedded inside frames or iframes on external websites. If this header is missing, attackers may load the website inside a malicious frame and trick users into performing unintended actions.

This type of attack is commonly known as **Clickjacking**.

Business Impact

The absence of this security header allows attackers to manipulate user interactions on a website. This may result in:

- Unauthorized actions performed by users
- Exposure of sensitive information
- Fraudulent transactions
- Loss of user trust and reputation damage

Vulnerability Path: http://www.itsecgames.com/

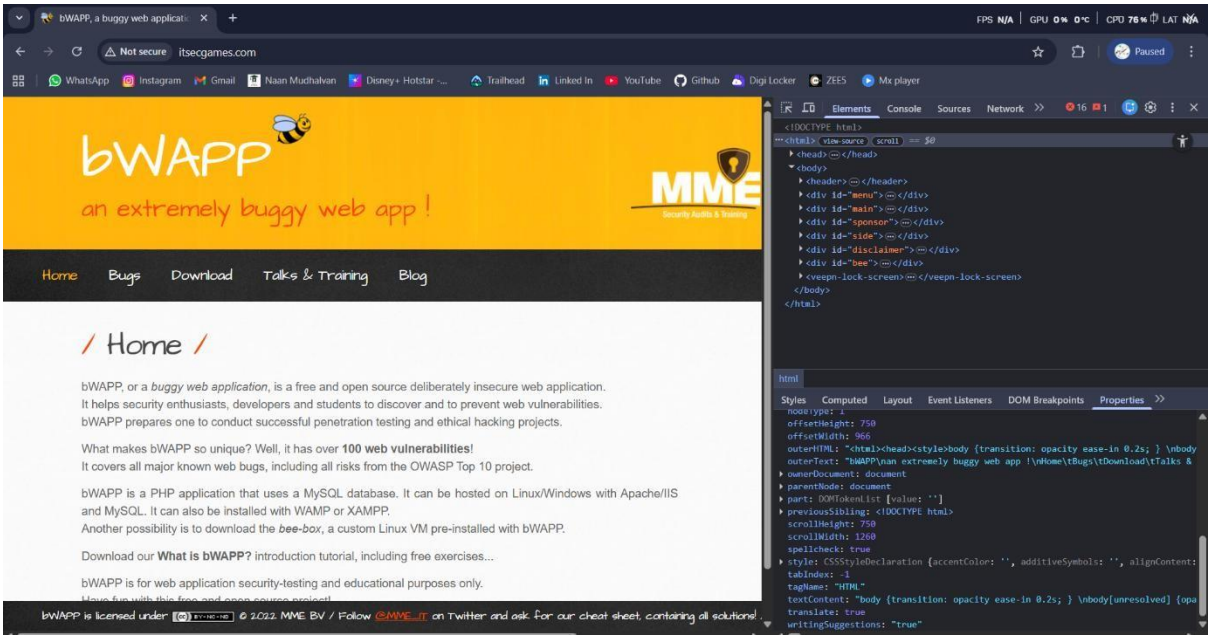
Steps to Reproduce

1. Open the practice website.

   http://www.itsecgames.com 2.

Open **Browser Developer Tools**.

3. Navigate to the **Network tab**.



4. Reload the page using **F5 or Ctrl + R**.
5. Select the HTML response request.
6. Check the **Response Headers**.

If the **X-Frame-Options header is missing**, the website is vulnerable to clickjacking attacks.

Recommendation

1. **Implement Proper UI Layer Access Controls:** Enforce access controls to restrict access to UI layers or frames based on user privileges.

2. **Use Session and Authentication Management:** Ensure robust session management and user authentication mechanisms to prevent unauthorized access.

3. **Implement Content Security Policies (CSP):** Use CSP headers to control where resources can be loaded from and mitigate against frame-based attacks.

4. **Keep Software and Libraries Updated**: Stay current with software updates and patches to address known security issues.

4) Vulnerability Name : X-Content-Type-Options Header Missing

CWE-918: Server-Side Request Forgery (SSRF)

OWASP Category : A10:2021 – Server-Side Request Forgery

Description

The **X-Content-Type-Options** header prevents browsers from performing MIME-type sniffing. When this header is missing, browsers may attempt to interpret content types automatically.

Attackers can exploit this behavior to disguise malicious scripts or files as legitimate content.

Business Impact

Missing this security header may lead to:

- Content-type manipulation attacks
- Data exposure
- Cross-site scripting attacks
- Unauthorized access to sensitive resources

These attacks may compromise application security and user data.

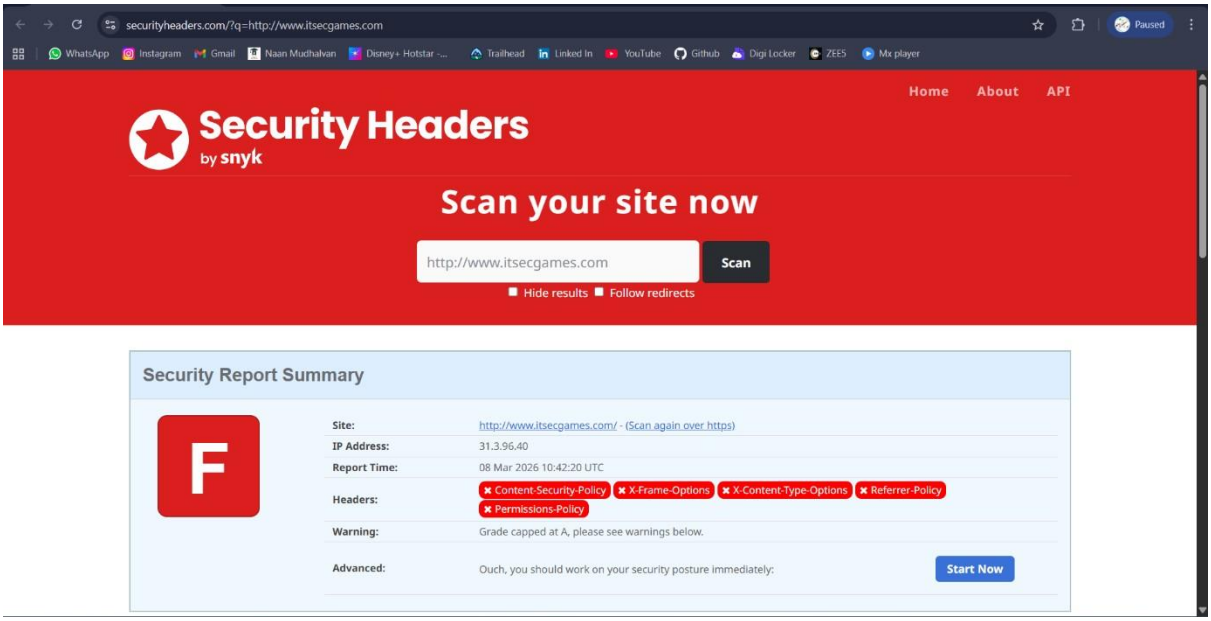
Steps to Reproduce

1. Open the **Security Headers analysis website**.

Example used:

https://securityheaders.com/?q=http://www.itsecgames.com

2. Enter the website URL and run the scan.
3. Review the report to identify missing security headers.



Recommendation

- Implement "X-Content-Type-Options" Header: Configure the "X-Content-TypeOptions" header with the value "nosniff" in your web server or application to prevent content type sniffing.

- Secure SSRF: To directly mitigate SSRF vulnerabilities, ensure proper input validation, access controls, and allow-list-based URL validation to prevent attackers from making unauthorized requests to internal resources.

- Security Headers: Implement other security headers like "X-Frame-Options" and "Content-Security-Policy" to further enhance security and mitigate various types of web-based attacks.

While the "X-Content-Type-Options" header may not be a direct countermeasure to SSRF, it is a valuable security control that, when configured correctly, can help protect against content type- based attacks that may be exploited in SSRF scenarios.

Vulnerability Name: **TLS Version 1.0 Protocol Detection**

CWE-327: Use of a Broken or Risky Cryptographic Algorithm

OWASP Category: A02:2021 – Cryptographic Failures

Description

During the security testing phase, the TLS configuration of the target server was analyzed to identify the encryption protocols supported by the web server.

The testing was performed using the **OpenSSL command-line tool**. The command attempts to establish a connection with the server using the **TLS 1.0 protocol**.

TLS 1.0 is an outdated encryption protocol that contains known cryptographic weaknesses. Modern security standards recommend disabling TLS 1.0 and replacing it with newer versions such as **TLS 1.2 or TLS 1.3**.

During the test, the connection attempt showed protocol negotiation issues, indicating that the server configuration is not properly supporting the requested TLS version or that outdated TLS configurations may still be present.

This vulnerability was also identified during the **Nessus vulnerability scan**, where the scanner detected that the target server supports deprecated TLS protocols.

Business Impact

Using outdated TLS protocols can create several security risks, including:

- Weak encryption mechanisms

- Possibility of cryptographic attacks
- Exposure of sensitive communication data
- Increased risk of data interception

If attackers exploit these weaknesses, they may intercept encrypted communication between the client and the server.

Steps to Reproduce

1. Open terminal or command prompt.
2. Run the following OpenSSL command to test TLS protocol support. openssl s_client -connect 31.3.96.40:443 -tls1

```
Bhuvi@Acer MINGW64 ~
$ ^C

Bhuvi@Acer MINGW64 ~
$ openssl s_client -connect 31.3.96.40:443 -tls1
Connecting to 31.3.96.40
CONNECTED(00000164)
903F0000:error:0A0000BF:SSL routines:tls_setup_handshake:no protocols available:
../openssl-3.5.4/ssl/statem/statem_lib.c:155:
---
no peer certificate available
---
No client certificate CA names sent
Negotiated TLS1.3 group: <NULL>
---
SSL handshake has read 0 bytes and written 7 bytes
Verification: OK
---
New, (NONE), Cipher is (NONE)
Protocol: TLSv1.3
This TLS version forbids renegotiation.
Compression: NONE
Expansion: NONE
No ALPN negotiated
Early data was not sent
Verify return code: 0 (ok)
---

Bhuvi@Acer MINGW64 ~
$ |
```

3. The command attempts to establish a connection with the server using TLS 1.0.
4. Observe the server response and protocol negotiation results.

This test helps determine whether the server supports outdated TLS protocols.

Tool Used

OpenSSL command-line tool

Recommendation

To mitigate this vulnerability, the following steps should be implemented:

1. Disable **TLS 1.0 and TLS 1.1** on the server.
2. Enable modern encryption protocols such as **TLS 1.2 or TLS 1.3**.
3. Configure secure cipher suites for HTTPS communication.

4. Regularly perform SSL/TLS security testing to ensure strong encryption standards.

Stage 2

Overview

Vulnerability Scanning using Nessus

In this stage, vulnerability assessment was performed using **Nessus Essentials**, a widely used vulnerability scanning tool developed by **Tenable Inc.** Nessus is used by security professionals to identify vulnerabilities, misconfigurations, and security weaknesses in networks, systems, and web applications.

Nessus operates using a **plugin-based vulnerability detection system**, where each plugin checks for a specific vulnerability or security issue. During a scan, Nessus sends multiple network probes to the target host and analyzes the responses to determine whether vulnerabilities exist.

In this project, Nessus was installed locally and accessed through the web interface using the following URL: https://localhost:8834

After the installation process, the Nessus plugins were compiled and updated to ensure accurate vulnerability detection. A **Basic Network Scan** was configured to analyze the target web server.

The target used for vulnerability scanning was **testfire.net**, which is a deliberately vulnerable web application designed for security testing and training purposes.

The scan analyzed the server configuration, open ports, encryption protocols, and web server information. After the scan completed, Nessus generated a detailed vulnerability report containing several informational and medium-severity findings.

How Nessus Works

The vulnerability scanning process performed by Nessus follows several steps:

1. Host Discovery

Nessus begins by identifying whether the target system is reachable using protocols such as **TCP, UDP, and ICMP**. This step confirms that the system is active and available for scanning.

2. Service Detection

After confirming the host is active, Nessus identifies the open ports and services running on the target system. This includes identifying web servers, databases, application servers, and other services.

3. Vulnerability Detection

Nessus executes multiple vulnerability detection plugins against the discovered services. Each plugin checks for specific vulnerabilities such as outdated software, weak encryption protocols, or insecure configurations.

4. Vulnerability Analysis

The scanner analyzes the responses from the target system to determine whether a vulnerability exists and assigns a severity level.

5. Report Generation

After completing the scan, Nessus generates a comprehensive report that includes:

- Vulnerability name
- Severity level
- Plugin identification number
- Description of the vulnerability
- Remediation recommendations

Benefits of Using Nessus

Nessus provides several advantages for vulnerability assessment:

- **Comprehensive vulnerability coverage** – Nessus contains thousands of plugins capable of detecting a wide range of vulnerabilities across systems and applications.
- **Ease of use** – The Nessus web interface allows users to easily configure and launch vulnerability scans.
- **Detailed reporting** – Nessus generates detailed reports that provide technical descriptions and remediation recommendations for each vulnerability.
- **Scalability** – Nessus can scan individual hosts, entire networks, or web applications.
- **Flexible scanning options** – Scans can be executed manually or scheduled periodically for continuous monitoring.

Due to these capabilities, Nessus is widely used by security professionals for vulnerability assessment and penetration testing.

Target Website

http://testfire.net

Target IP Address

65.61.137.117

The website **testfire.net** is a purposely vulnerable web application designed for security testing and training purposes. It allows security professionals and students to perform vulnerability scans safely without affecting real production systems.

List of vulnerability:-

s.no	Vulnerability name	Severity	plugins
1	TLS Version 1.1 Protocol Deprecated	MEDIUM	157288
2	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)	LOW	83875
3	HTTP Multiple Issues	INFO	10107
4	SSL Multiple Issues	INFO	51192
5	TLS Multiple Issues	INFO	42873

6	IETF MD5 Multiple Issues	INFO	35291
7	Service Detection	INFO	22964
8	Apache Tomcat Detection	INFO	39446
9	Nessus SYN Scanner	INFO	11219
10	Additional DNS Hostnames	INFO	46180

REPORT:-

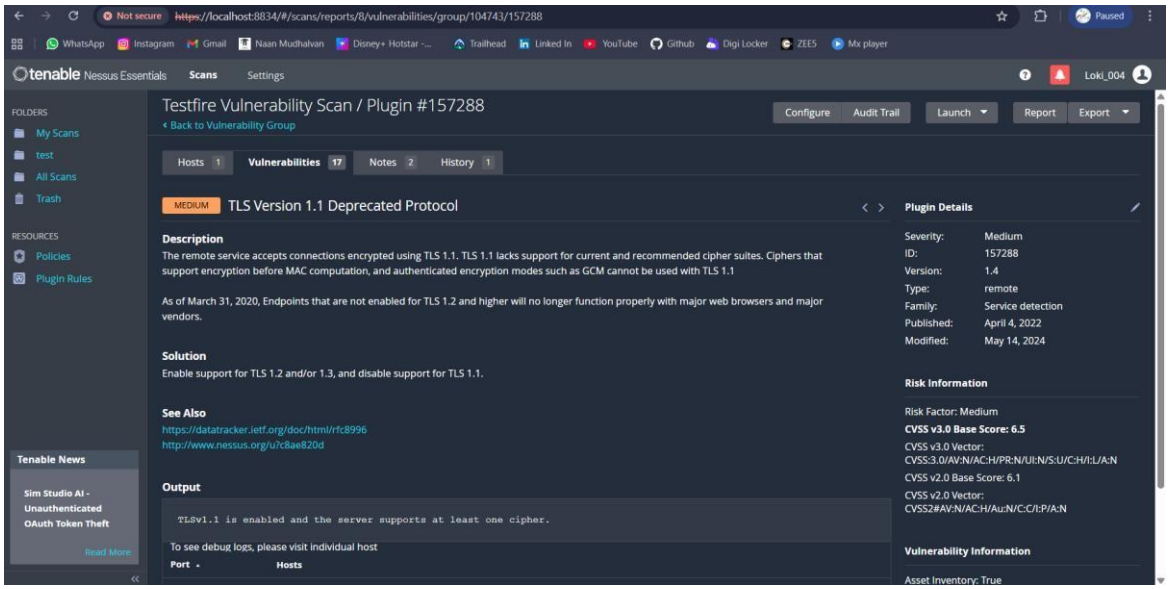
1) Vulnerability Name: - 157288 - TLS Version 1.1 Protocol Deprecated

Severity: - MEDIUM **Plugin:**
- 157288

Port: - 443

Description: -
The remote service accepts connections encrypted using **TLS 1.1 protocol**. TLS 1.1 lacks support for modern encryption algorithms and recommended cipher suites. Ciphers that support encryption before MAC computation and authenticated encryption modes such as GCM cannot be used with TLS 1.1.

As of March 31, 2020, endpoints that are not enabled for **TLS 1.2 or higher** will no longer function properly with major web browsers and vendors.



"TLS Version 1.1 Deprecated Protocol – Plugin ID 157288"

Solution: -
Enable support for **TLS 1.2 and TLS 1.3** and disable support for TLS 1.1.

Business Impact: -
Using outdated encryption protocols can expose systems to cryptographic attacks and data interception. It may also cause compatibility issues with modern browsers and reduce the overall security of the server.

2) Vulnerability Name: - 83875 - SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)

Severity: - LOW **Plugin:**
- 83875

Port: - 443

Description: -
The remote host allows SSL/TLS connections with Diffie-Hellman parameters that are **less than or equal to 1024 bits**. Weak Diffie-Hellman parameters may allow attackers to perform cryptographic attacks such as the **Logjam attack**.

Solution: -
Reconfigure the server to use **Diffie-Hellman parameters of 2048 bits or greater**.

Business Impact: -
Weak encryption parameters may allow attackers to compromise encrypted communications and potentially recover sensitive data transmitted over the network.

3) Vulnerability Name: - 10107 - HTTP Multiple Issues

Severity: - INFO **Plugin:**
- 10107

Port: - 80

Description: -
This vulnerability indicates that the server has multiple informational issues related to the HTTP service configuration.

Solution: -
Review HTTP server configurations and ensure that unnecessary information is not exposed to users or attackers.

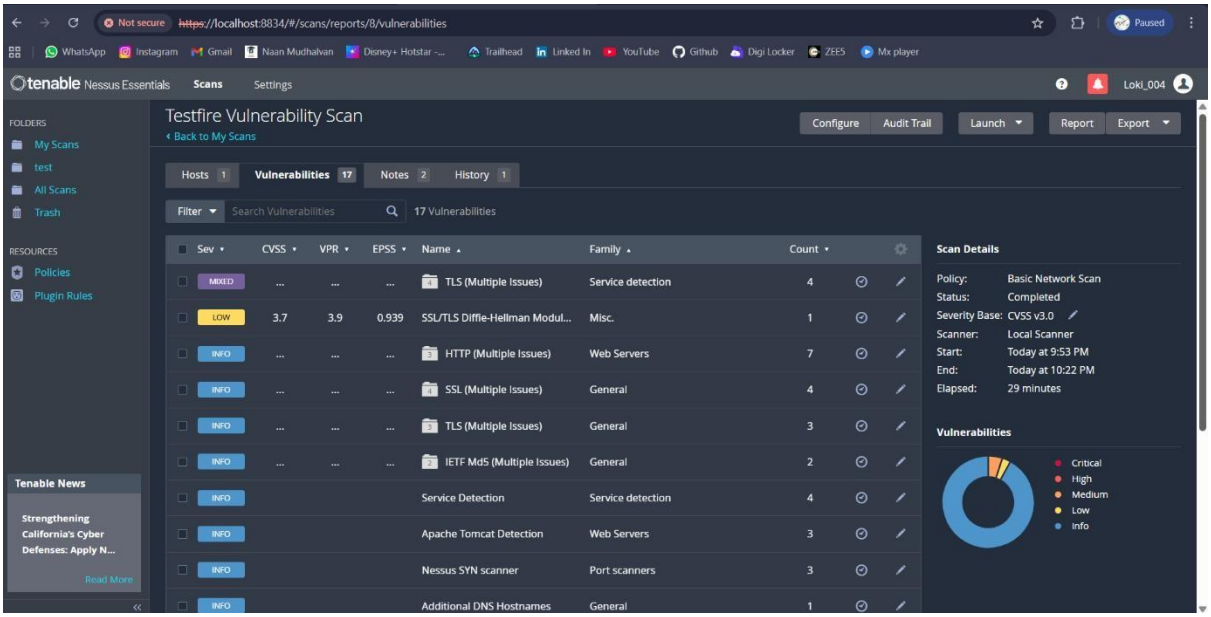
Business Impact: -
While this issue does not directly affect system functionality, exposing server information may help attackers identify potential weaknesses in the system.

4) Vulnerability Name: - 51192 - SSL Multiple Issues

Severity: - INFO **Plugin:**
- 51192

Port: - 443

Description: -
The Nessus scan detected several informational findings related to the SSL configuration of the remote server.



Solution: -
Review the SSL configuration and ensure that recommended security standards are followed.

Business Impact: -
Improper SSL configuration can weaken the encryption security and may expose the server to potential attacks.

5) Vulnerability Name: - 42873 - TLS Multiple Issues

Severity: - INFO
Plugin: - 42873

Port: - 443

Description: -
The scan detected multiple TLS-related informational findings related to encryption configuration.

Solution: -
Ensure that only secure TLS versions and cipher suites are enabled.

Business Impact: -
Improper TLS configuration may reduce the overall security of encrypted communications.

6) Vulnerability Name: - 35291 - IETF MD5 Multiple Issues

Severity: - INFO **Plugin:**
- 35291

Port: - 0

Description: -
The scan detected MD5 related cryptographic components. MD5 is considered a weak hashing algorithm and should not be used for security-sensitive operations.

Solution: -
Replace MD5 with stronger hashing algorithms such as **SHA-256 or SHA-512**.

Business Impact: -
Weak hashing algorithms may allow attackers to compromise data integrity and authentication mechanisms.

7) Vulnerability Name: - 22964 - Service Detection

Severity: - INFO **Plugin:**
- 22964

Port: - 0

Description: -
This plugin identifies services running on the remote host.

Solution: -
Administrators should review exposed services and ensure that unnecessary services are disabled.

Business Impact: -
Service discovery information may assist attackers in identifying potential attack vectors.

8) Vulnerability Name: - 39446 - Apache Tomcat Detection

Severity: - INFO
Plugin: - 39446

Port: - 80

Description: -
Nessus detected that the server is running **Apache Tomcat**, which is a Java based web application server.

Solution: -
Ensure that Apache Tomcat is updated and properly configured with secure access controls.

Business Impact: -
Outdated versions of Apache Tomcat may contain vulnerabilities that attackers could exploit.

9) Vulnerability Name: - 11219 - Nessus SYN Scanner

Severity: - INFO
Plugin: - 11219

Port: - 0

Description: -
This plugin performs SYN scanning to identify open ports on the target system.

Solution: -
Administrators should review open ports and disable unnecessary services.

Business Impact: -
Open ports may expose services that could be targeted by attackers.

10) Vulnerability Name: - 46180 - Additional DNS Hostnames

Severity: - INFO **Plugin:**
- 46180

Port: - 0

Description: -
The Nessus scan detected additional DNS hostnames associated with the target server.

Solution: -
Review DNS configurations and ensure that only required hostnames are exposed.

Business Impact:

This relates to the identification of the remote web server's type and version. While this issue doesn't pose an immediate security threat, it can provide valuable information to potential attackers about the server's software stack. Knowledge of the server type and version may aid attackers in exploiting known vulnerabilities specific to that software, making it important to restrict such information from being easily accessible to enhance the server's overall security posture.

Stage – 3

Title: **Replace and Modernize Legacy VPN Architectures with a Cloud-Native Zscaler Zero Trust Solution to Reduce Attack Surface and Lateral Movement**

Legacy VPN Architecture

Legacy VPN architecture is a traditional network security model used to allow remote users to access an organization's internal network through an encrypted tunnel. This architecture typically relies on **on-premises hardware appliances**, such as VPN concentrators, firewalls, or gateways.

In a legacy VPN model, once a user successfully authenticates, the system grants **full network access**, assigning the user an internal IP address. This effectively makes the remote user appear as if they are directly connected to the internal network.

This approach follows the **"authenticate once, trust indefinitely"** principle. After authentication, the user gains broad access to internal resources based on network location rather than identity verification.

Legacy VPN architecture was originally designed for environments where:

- Employees worked primarily inside office networks.
- Applications were hosted in centralized data centers.
- Remote access requirements were limited.

This model follows the **"castle-and-moat" security concept**, where the internal network is considered trusted and the external internet is considered untrusted. The VPN gateway acts as the bridge between the two environments.

Once a user enters through the VPN gateway, they are often trusted with **extensive access privileges**, which increases the risk of internal security threats.

Limitations of Legacy VPN

Legacy VPN solutions introduce several **security and operational challenges**, especially in modern distributed environments where users work remotely and applications are hosted in the cloud.

The major limitations include:

1. Over-Permissioned Access

Once a user connects through the VPN, they gain **network-level access** to internal systems. If a device becomes compromised, attackers can scan and access other systems within the network.

2. Expanded Attack Surface

VPN gateways must be exposed to the public internet through open ports such as:

- **UDP 500 (IPSec VPN)**
- **TCP 443 (SSL VPN)**

These exposed services become attractive targets for attackers conducting:

- Port scanning
- Credential brute-force attacks
- Vulnerability exploitation

3. Poor User Experience

Legacy VPN solutions often require traffic to be routed through the corporate data center before reaching external applications. This process is known as **traffic hairpinning**, which causes:

- Increased latency
- Reduced performance
- Slower application access

4. Scalability Issues

Hardware VPN appliances have **fixed capacity limits**. During high-traffic periods, such as remote work spikes, users may experience:

- Connection failures
- Network congestion
- Reduced service availability

Upgrading hardware appliances also increases operational costs.

5. Operational Overhead

IT administrators must continuously manage VPN infrastructure, including:

- Hardware maintenance
- Firmware updates
- Certificate management
- Security patching

This increases administrative workload and operational complexity.

The Problem: Lateral Movement and Attack Surface

The most critical security issues associated with legacy VPN architectures are:

Expanded Attack Surface

Since VPN gateways are publicly exposed, attackers frequently scan the internet searching for vulnerable VPN devices.

Attackers may exploit vulnerabilities such as:

CVE-2019-11510 – Pulse Secure VPN vulnerability

Once exploited, attackers gain unauthorized access to internal networks.

Lateral Movement

After gaining initial access, attackers can move laterally within the network.

Examples of lateral movement activities include:

- Scanning internal systems
- Accessing databases or file servers
- Performing credential harvesting attacks
- Pivoting to sensitive systems

This can lead to severe security incidents such as:

- Data breaches
- Ransomware attacks
- Unauthorized access to confidential information

Zero Trust Architecture

Zero Trust Architecture (ZTA) is a security framework that eliminates the concept of trusted and untrusted networks. It operates on the principle of "never trust, always verify" and "least privilege access." Every access request is fully authenticated, authorized, and encrypted before granting access, regardless of whether the user is in the office or working remotely .

The core tenets of Zero Trust include:

1. Assume Breach: Design the network as if attackers are already present.
2. Verify Explicitly: Authenticate and authorize based on identity, device health, and context.
3. Least Privilege Access: Grant only the minimum access necessary to perform a job function.
4. Micro-segmentation: Isolate workloads and users from one another to prevent lateral movement.

Instead of trusting users based on network location, Zero Trust follows the principle:

“Never Trust, Always Verify.” Every

access request must be:

- Authenticated
- Authorized
- Continuously verified before granting access to resources.

Key principles of Zero Trust include:

1. Assume Breach

Systems should be designed under the assumption that attackers may already be inside the network.

2. Verify Explicitly

Access decisions should consider multiple factors including:

- User identity
- Device health
- Location

- Security posture

3. Least Privilege Access

Users receive only the minimum permissions necessary to perform their tasks.

4. Micro-Segmentation

Applications and systems are isolated from each other to prevent attackers from moving laterally within the network.

Zscaler Zero Trust Solution

Zscaler is a cloud-native security platform that delivers Zero Trust capabilities entirely from the cloud, eliminating the need for on-premises VPN hardware. The solution consists of two primary components relevant to this project:

1.Zscaler Private Access (ZPA): A ZTNA service that provides seamless, identitybased access to private applications without placing users on the network. It connects users to applications, not the network .

2. Zscaler Internet Access (ZIA): A secure web gateway that inspects all internet-bound traffic for threats and data loss, protecting users regardless of location . Together, they create a comprehensive Zero Trust replacement for legacy VPN architectures.

Zscaler provides two primary services:

Zscaler Private Access (ZPA)

ZPA provides secure access to **private applications** without connecting users to the internal network.

Instead of connecting users to the network, ZPA connects users **directly to specific applications**.

Zscaler Internet Access (ZIA)

ZIA acts as a **secure web gateway**, protecting users from internet-based threats by inspecting outbound traffic.

ZIA provides features such as:

- Web filtering
- Malware protection
- Data loss prevention
- Threat intelligence enforcement

Together, ZPA and ZIA create a secure Zero Trust architecture that replaces traditional VPN systems.

How Zscaler Eliminates Attack Surface

Zscaler eliminates the attack surface by making internal applications **invisible to the public internet**.

This is achieved through several mechanisms:

No Inbound Ports

Zscaler App Connectors initiate **outbound connections** to the Zscaler cloud. No inbound firewall rules are required.

Application Invisibility

External attackers cannot detect internal applications because:

- No public IP addresses are exposed
- No open ports are available for scanning

DNS Protection

Internal applications are not published through public DNS servers, preventing external discovery.

Dark Cloud Model

Zscaler acts as a secure broker between users and applications. Users never see the internal server IP addresses, and servers never see the user's IP address.

How Zscaler Prevents Lateral Movement

Zscaler prevents lateral movement by ensuring that users **connect only to authorized applications**, not the entire network.

Security mechanisms include:

Application Segmentation

Each user receives a dedicated encrypted connection to a specific application.

No Network Visibility

Users are not assigned internal IP addresses, preventing them from scanning or accessing other systems.

Identity-Based Policies

Access decisions are based on user identity rather than network location.

Continuous Monitoring

User sessions are monitored continuously, and suspicious activities can trigger automatic connection termination.

Zscaler Architecture Components

The Zscaler Zero Trust architecture consists of several components.

Zscaler Client Connector

A lightweight software client installed on user devices that securely routes traffic to Zscaler services.

Zscaler App Connector

A virtual machine deployed inside the organization's data center that securely connects internal applications to the Zscaler cloud.

Zscaler Cloud

A globally distributed security platform responsible for policy enforcement and traffic inspection.

Zscaler Admin Portal

A centralized management interface used to configure:

- Access policies
- Application definitions
- Security configurations
- User management

Integration Points

Zscaler integrates with existing enterprise infrastructure.

Identity Provider Integration

Zscaler integrates with identity platforms such as:

- Azure Active Directory
- Okta

This enables Single Sign-On (SSO) and Multi-Factor Authentication (MFA).

Endpoint Security Integration

Zscaler integrates with endpoint protection tools such as:

- Microsoft Defender

- CrowdStrike
- Tanium

Access can be restricted based on device security posture.

SIEM Integration

Security logs from Zscaler can be forwarded to SIEM platforms such as:

- Splunk
- Microsoft Sentinel

This allows centralized security monitoring.

MISP Threat Intelligence Integration

MISP (Malware Information Sharing Platform) is an open-source threat intelligence system used to share indicators of compromise (IOCs).

MISP collects data such as:

- Malicious IP addresses
- Phishing domains
- Malware hashes
- Command-and-control servers

Zscaler integrates with MISP using APIs to automatically ingest threat intelligence feeds.

When a user attempts to access a malicious resource identified by MISP, Zscaler automatically blocks the request.

Deployment Methodology

Deploying Zscaler to replace the legacy VPN requires a structured, phased approach:

Phase 1: Discovery and Planning (Weeks 1-2)

1. Application Discovery: Catalog all internal applications currently accessed via VPN. This includes:
    - Student Information System (SIS)

- ERP (Finance/HR)
- Library resources
- Research computing clusters
- Internal file servers
- Administrative portals

2. User Segmentation:Define user groups and their application access requirements:

   - Faculty: ERP, research servers, file shares
   - Students: Library resources, learning management system
   - Staff: Administrative portals, finance applications
   - IT Admins: Server management interfaces o External Collaborators: Specific research applications only

3. Traffic Analysis: Understand current traffic patterns to plan Zscaler Internet Access (ZIA) forwarding methods (PAC file, tunnel, or proxy). **Phase 2: Infrastructure Deployment (Weeks 3-4)**

1. Deploy App Connectors:
   - Provision App Connector VMs in the university data center (minimum 2 for high availability)
   - Configure them with outbound internet access to connect to Zscaler cloud
   - No inbound firewall rules required
2. Configure App Connector Groups:
   - Group connectors by function or location
   - Associate them with specific applications for traffic steering

3. Integrate Identity Provider:
   - Configure SAML 2.0 between Zscaler and Azure AD
   - Map user groups from Azure AD to Zscaler
   - Test authentication flow

Phase 3: Policy Configuration (Weeks 5-6)

1. Define Applications in ZPA:
   - Add each internal application (by IP, port, and protocol)
   - Associate applications with App Connector groups
   - Configure application segmentation
2. Create Access Policies:
   - Build granular policies based on user groups:

- "Faculty can access ERP on TCP 443 from devices with antivirus enabled after MFA"
- "Researchers can access HPC Cluster on TCP 22 from managed devices only"
- *"External Collaborators can access Research Repository on TCP 443 between 9 AM-5 PM"*

3. Configure ZIA Policies:
    - Set up URL filtering
    - Enable threat protection (IPS/IDS)
    - Configure data loss prevention (DLP) rules for sensitive data

Phase 4: Pilot Deployment (Weeks 7-8)

1. Select Pilot Group: Choose a small group of willing faculty and IT staff (10-20 users).
2. Deploy Zscaler Client Connector: Provide installation instructions and assist with setup.
3. Monitor and Validate:
    - Verify authentication and MFA flows
    - Test application access
    - Validate that users cannot access unauthorized applications
    - Collect feedback on performance
4. Refine Policies: Adjust based on pilot feedback and any access issues.

Phase 5: Full Deployment and Migration (Weeks 9-12)

1. Phased Rollout: Deploy to user groups in waves:
    - Week 9: Faculty and researchers
    - Week 10: Administrative staff o Week 11: Students (if applicable)
    - Week 12: IT staff and remaining users
2. Communication and Training:
    - Send pre-deployment emails with instructions
    - Provide user guides for Zscaler Client Connector
    - Establish support channels for issues
3. Legacy VPN Decommissioning:
    - Once all users are migrated, revoke legacy VPN access
    - Shut down VPN concentrators
    - Remove public DNS records pointing to VPN

Phase 6: Optimization and Continuous Improvement (Ongoing)

1. Log Analysis: Regularly review Zscaler logs in the admin portal for anomalies.
2. Policy Refinement: Update policies based on changing user roles and application additions.
3. Threat Hunting: Use integrated threat intelligence (MISP) to proactively search for compromised accounts.

Threat Intelligence in Zscaler Environment

Threat intelligence transforms Zscaler from an access control tool into a proactive security platform. It provides context about who is trying to access what, from where, and with what risk.

Sources of Threat Intelligence:

1. Zscaler Cloud Logs: Real-time data on connections, including:
    - User identity and group membership
    - Source IP and geolocation
    - Destination application and IP
    - Bytes transferred and session duration
    - Device posture information
2. External Threat Feeds (MISP): Structured IOCs from trusted sources:
    - Known malicious domains (e.g., phishing sites)
    - Command-and-control server IPs
    - Ransomware distribution URLs
    - File hashes of malware samples
3. Identity Provider Logs: Authentication data from Azure AD:
    - Successful and failed login attempts
    - MFA status
    - Impossible travel anomalies
4. EDR Integration: Endpoint detection tools provide:
    - Compromised device alerts
    - Malware detections o Anomalous process behavior

Applications of Threat Intelligence:

1. Adaptive Access Control:
    - If threat intelligence identifies a user's source IP as high-risk (e.g., known TOR exit node or malicious VPN), Zscaler can:
        - Step-up authentication (require additional MFA)
        - Block access entirely Restrict to read-only access
2. Compromised Account Hunting:
    - Analysts query Zscaler logs to identify:
        - Users accessing applications at unusual hours
        - Unusual data transfer volumes (potential exfiltration)
        - Access from unusual geographic locations
    - Cross-reference with MISP to see if destination IPs are known malicious
3. Proactive Threat Blocking:
    - MISP feeds are pushed to ZIA for real-time enforcement
    - When any user attempts to access a blocked domain, the request is denied

- Alerts are generated for security team investigation.

Incident Response in Zero Trust Model

Incident response is fundamentally improved in a Zscaler Zero Trust environment. The ability to instantly revoke access and the inherent lack of lateral movement transforms how security teams respond to threats. Incident Response Workflow:

1. Detection:
    - Alert Trigger: The SOC receives an alert from Zscaler logs or integrated EDR tool. Example: A faculty account is downloading 50GB of research data at 3:00 AM, far exceeding normal behavior.
    - Investigation Initiation: The analyst opens the Zscaler admin portal and views the session details:
        - User: Dr. Smith (Faculty_Research group)
        - Device: Laptop "FAC-LT-342" (Windows 11, Defender active)
        - Application: Research Data Repository (SMB share)
        - Data transferred: 50GB in 15 minutes
        - Source IP: Unusual location (country different from user's normal location)

2. Containment:
    - Instant User Isolation: The analyst navigates to the user profile in the Zscaler portal and clicks "Deactivate User" or "Block Device." This action:
        - Terminates all active Zscaler connections immediately
        - Prevents any new authentication attempts
        - Takes effect globally within seconds (no firewall rules to update)
    - Impact of Containment: Because the user was never on the network, there is no lateral movement to contain. The attacker is limited to the single compromised application and cannot pivot.
3. Eradication:
    - The compromised device is remotely wiped or taken offline by IT helpdesk. • The user's password is reset in Azure AD.
    - The analyst checks MISP and Zscaler logs to determine how the account was compromised (e.g., phishing email received earlier that day).
    - The malicious domain from the phishing email is added to Zscaler's block list (or automatically ingested via MISP).
4. Recovery:
    - Once the device is clean (re-imaged or malware removed) and the password is reset, the analyst re enables the user in Zscaler.
    - The user authenticates with MFA from a clean device and regains access only to authorized applications.

- All subsequent activity is closely monitored for 24-48 hours.

5. Post-Incident Review:
    - The security team analyzes the incident to identify root cause and process improvements.
    - Zscaler policies are updated: perhaps additional restrictions on sensitive research data (e.g., require approval for downloads over 1GB).

Benefits of ZTNA-Based Incident Response:

1. Containment Speed: Actions take seconds in a cloud dashboard versus hours reconfiguring firewall ACLs or disabling VPN accounts .
2. No Lateral Movement: The blast radius is limited to the single compromised application; the rest of the university network remains protected .
3. Complete Audit Trail: Zscaler provides granular logs of every connection, session, and data transfer for forensic analysis .
4. Remote-First Design: Incident response can be conducted entirely from the cloud, without requiring physical access to data center equipment .
5. Compliance Demonstration: The detailed logs and access controls help demonstrate compliance with FERPA, HIPAA (if applicable), and other regulations .

Threat Intelligence in Zscaler Environment

Threat intelligence enhances the security capabilities of the Zscaler platform.

Sources of threat intelligence include:

- Zscaler security logs
- MISP threat feeds
- Identity provider logs
- Endpoint detection systems

This intelligence enables proactive threat detection and adaptive security policies.

Incident Response in Zero Trust Model

Zero Trust significantly improves incident response capabilities.

When suspicious activity is detected:

1. Security analysts investigate the event.
2. Access for the affected user or device is immediately revoked.

3. The compromised device is isolated.
4. Security teams analyze logs to determine the root cause.
5. Access is restored only after remediation.

Because users are never connected directly to the internal network, the impact of an attack is significantly reduced.

Conclusion: -

In conclusion, exploring the realm of AI for web security using IBM QRadar has been an insightful journey through various stages.

In **Stage 1,** understanding web application testing unveiled the critical importance of assessing vulnerabilities and ensuring the security of web-based systems. This foundational knowledge served as a cornerstone for comprehending the subsequent stages.

Stage 2 delved into the intricacies of Nessus reports, emphasising the significance of detailed vulnerability assessments. Analysing these reports provided valuable insights into potential threats, enabling informed decision-making for robust security measures.

Stage 3 The replacement of the legacy VPN architecture with a cloud-native Zscaler Zero Trust solution marks a pivotal transformation in the organization's security posture. By shifting from a network-centric to an application-centric model, this project successfully eliminates the expanded attack surface inherent in publicly exposed VPN concentrators and completely eradicates the risk of lateral movement. The implementation of Zscaler Private Access (ZPA) ensures that users are connected only to specific applications after rigorous identity and device verification, rendering the internal network invisible. This modernization not only fortifies defenses against sophisticated cyber threats but also delivers a superior, low-latency experience for the hybrid workforce, establishing a future-ready security foundation.

Considering the future scope, **Stage 1** illuminated the evolving landscape of web application testing. With advancements in AI, there is a promising avenue for more sophisticated testing methodologies, ensuring even higher levels of security for web applications.

Stage 2 highlighted the future trajectory of the testing process, indicating a shift towards more automation and integration of AI-driven tools. This evolution promises quicker, more accurate vulnerability assessments, enhancing overall cybersecurity postures.

Stage 3 illuminated the future potential of Zero Trust Network Access (ZTNA) and Zscaler technologies. With AI integration and machine learning, these systems are

poised to become more intelligent and adaptive, enabling real-time risk assessment based on user behavior and device posture. Enhanced automation in policy enforcement, predictive analytics for threat detection, and improved scalability are anticipated, empowering organizations to stay ahead of sophisticated cyber threats in an increasingly distributed world. In essence, the project not only provided a deep understanding of the current state zero trust using ZSCALER but also offered a glimpse into the exciting future of cybersecurity. Embracing these advancements will be crucial for organisations aiming to fortify their digital landscapes in the face of everevolving cyber threats.

Future scope of the testing process

The future scope of the testing process is bright, as software becomes increasingly complex and sophisticated. Organisations are increasingly reliant on software to conduct business, and they need to be confident that their software is high-quality and reliable.

Here are some of the key trends that are expected to shape the future of the testing process:

- Increased focus on continuous testing: Continuous testing is a methodology that involves testing software throughout the SDLC, from development to deployment. This helps to identify defects early and prevent them from causing problems later in the development process.

- Rise of AI and ML: AI and ML are already being used in the testing process, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.

- Shift to cloud-based testing: Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness. This is driving the growth of cloud-based testing platforms.

- Increased focus on testing automation: Testing automation is the use of software to execute test cases without human intervention. Testing automation can help to save time and resources, and it can also help to improve the quality and efficiency of testing.

Future scope of SOC / SEIM:-

While the current project successfully replaces the legacy VPN with Zscaler ZPA for remote access, the Zero Trust journey offers several avenues for future expansion and enhancement:

1.Workload-to-Workload Segmentation: Extend Zero Trust principles beyond userto application connectivity to secure communication between internal workloads themselves. By deploying Zscaler Workload Segmentation, the university can enforce

micro-segmentation within the data center and cloud environments, preventing lateral movement even between application tiers (e.g., web server to database server) without relying on network firewall rules.

2. Branch and Campus Transformation: Expand the Zscaler deployment to eliminate MPLS circuits and traditional hub-and-spoke networking. By routing all branch and campus internet traffic directly through Zscaler Internet Access (ZIA), the organization can reduce costs, improve performance, and apply consistent security policies to all users, regardless of their physical location.

3.OT and IoT Security Integration: Extend Zero Trust coverage to operational technology (OT) and Internet of Things (IoT) devices on campus, such as building management systems, security cameras, and lab equipment. Zscaler can provide visibility and segmentation for these often-unmanaged devices, ensuring they cannot be used as an entry point to attack core academic systems.

4.Advanced Data Loss Prevention (DLP): Enhance Zscaler deployment with advanced DLP capabilities to protect sensitive research data and student information. Future phases can include fingerprinting of sensitive documents, exact data matching (EDM) for structured data like student records, and integration with insider threat management tools to detect and block anomalous data exfiltration attempts.

5.AI-Driven Threat Hunting: Leverage Zscaler's AI-powered analytics and the integration with threat intelligence platforms like MISP to implement proactive threat hunting. Machine learning models can baseline normal user behavior and automatically flag anomalies—such as impossible travel or unusual data access patterns—for immediate investigation by the security operations center (SOC).

6.Privileged Remote Access for Vendors: Formalize and secure access for external vendors and contractors who require temporary access to specific systems for maintenance and support. Zscaler's privileged remote access capabilities can provide time-bound, session-recorded, and approval-based access to critical infrastructure without granting network-level privileges.

7.Integration with SOAR Platforms: Integrate Zscaler with security orchestration, automation, and response (SOAR) platforms to enable automated incident response workflows. For example, if Zscaler detects a compromised device, the SOAR platform can automatically trigger service desk tickets, isolate the device from the network, and reset the user's Active Directory credentials.

8.Continuous Compliance Automation: Utilize Zscaler logs and APIs to automate compliance reporting for regulations such as FERPA, GDPR, and HIPAA. Future development can include real-time compliance dashboards that demonstrate leastprivilege access, data protection controls, and audit readiness to regulators and internal auditors.

9.Zero Trust for Mergers and Acquisitions: As the university grows or partners with other institutions, Zscaler can provide a secure framework for rapidly integrating new users and applications. Zero Trust principles ensure that acquired entities can access

specific resources without being placed on the internal network, maintaining security during transitional periods.

10. User Behavior Analytics (UBA): Implement advanced user behavior analytics to detect insider threats and compromised accounts. By analyzing patterns of application access, data transfer volumes, and login times, machine learning algorithms can identify subtle indicators of malicious activity that rule-based policies might miss.

Topics Explored

- Data Collection and Aggregation
- Threat Intelligence Analysis
- Security Information and Event Management (SIEM)
- Incident Response
- Threat Intelligence Feeds
- Security Automation

Tools Explored

- Git Bash
- Metasploit
- Nessus
- Openssl
- Nmap

THE END